

Ink Morrow

WHERE STORIES GROW CLAWS

5.0 EDITION

Security, Privacy & AI Boundary

What crosses the threshold, what stays local, and who remains in control

For operators, players, and security reviewers / September 2026

Security, Privacy & AI Boundary

InkMorrow is private-by-default self-hosted software for one owner. This book distinguishes browser access, filesystem access, provider exposure, generated prose and portable files.

Contents

Threat model and trust map
Data inventory and retention
Authentication, origin and network
Credential lifecycle
Untrusted output and semantic limits
Uploads, saves and historical data
Reporting and operator checks
Optional reviewer exposure and authority
Relationships, episodes and return recaps
Characters addressing the user
Influence and recall boundary
Resistance is not a security boundary
Images and saves
Reader boundary

01 Threat model and trust map

The owner controls the machine, network, provider profiles and downloaded files. The browser password protects the HTTP application; it does not encrypt all data at rest or protect against someone who controls the operating-system account.

Boundary	Trusted responsibility	Untrusted input
Browser to server	Auth, origin, CSRF, bounded parsing	URLs, bodies, filenames, stale revisions
Server to SQLite/media	Transactions, private paths, integrity	Old files, corrupt journals, imported graphs
Server to provider	Explicit exposure and bounded dispatch	Model prose, effects, reviews, errors, costs
Story to reader	Public current-path projection	Hidden state and other-path references
Story to book	Selected prose and current illustrations	Private metadata accidentally included
Story to save	Complete validated continuation graph	Imported fields, cycles and media bytes

A fictional character's refusal is not real authorisation. The owner can correct world facts through authenticated local controls; narration cannot use claimed royal authority to change application permissions.

No hosted multi-user account boundary, MFA or email recovery is claimed. Deploying the software for other people or adding remote access changes the threat model and needs a deliberate review.

B1 keeps all five rooms behind the existing authenticated bootstrap. Lock hides and clears current story content, contribution buffers and password fields before awaiting logout; stale result handlers remain fenced by the lifecycle epoch. Room changes within the same story retain pending-operation authority instead of creating a new purchase. The full-height contribution task and paid review share the modal stack; background dialogs are inert and hidden from accessibility while the top review is active.

Browser storage for reading return contains bounded IDs and relative anchors, not prose, private world truth, credentials or contribution drafts. Historical Codex/timeline/evidence queries restrict data to the inspected ancestry and moment. Hidden-only changes are filtered before pagination. Submitted text and correction reasons remain outside public evidence; narration quotes carry the exact immutable source hash, while legacy records retain passage-level attribution. Private planning uses an explicit authenticated route and clears its DOM on leaving. Owner drafts stay in authenticated SQLite storage, never browser prose storage; compare-and-swap prevents silent cross-tab overwrites. Lock cancels queued writes, clears UI and fences late callbacks. Acknowledged in-flight writes may finish. Unknown request status does not authorize a replacement purchase: cancellation fences block a delayed undispatched original. Ordinary and quality approval resets clear the corresponding local/session consent family and do not cancel already authorized work. Book/private-save exposure boundaries remain distinct in Gate.

02 Data inventory and retention

The database holds owner authentication, session digests, provider assignments, encrypted vault material, playable graphs and model-call accounting. Normalized images live under the configured media root. The environment file may hold a plaintext provider credential protected by filesystem permissions.

Story data includes private motives, hidden world truths, directions and correction reasons as well as visible prose. Branch snapshots preserve earlier states. Removing a placement does not erase its historically referenced image. Retiring a fact is not secure deletion of its old versions.

Call metadata records roles, purposes, models, status and known/unknown charges. Rejected candidates and reviewer explanations are not saved as playable history. Do not claim that the remote provider also discards them: its retention is an independent service policy.

A book contains selected-path reading material. A playable save contains all paths and private state, but no credentials, provider configuration, consent or pending request authority. A cold installation backup contains more, including auth and vault records, and must be protected accordingly.

Browser consent flags are convenience preferences; the session CSRF token is held in memory. Keys entered in Settings are not placed in browser persistence. Lock clears private runtime state. Operating-system swap, backups and external provider logs are outside that UI clearing guarantee.

03 Authentication, origin and network

Setup requires a random terminal code and a distinctive 15–128-character NFC-normalized password. Password hashing uses asynchronous scrypt with random salt. Only opaque session-token digests are stored. Cookies are HttpOnly and SameSite=Strict, and Secure when the trusted request is HTTPS.

Remembered sessions have a seven-day idle and thirty-day absolute lifetime; unremembered sessions use eight hours idle and twenty-four hours absolute. Lock revokes one session. Password change revokes the others. Setup/login have bounded progressive delays and temporary attempt limits, not permanent lockout.

Private API guards execute before body parsing. Mutations need CSRF and same origin. Host validation limits DNS rebinding; restrictive headers constrain script, framing, MIME sniffing and referrer exposure. Static documentation remains public so a locked-out owner can read recovery instructions.

The executable forces auth on, even under NODE_ENV=test. Loopback is the default bind. Direct non-loopback HTTP requires explicit insecure-LAN opt-in. Prefer HTTPS through a loopback proxy with explicit allowed hosts and trusted-proxy configuration when remote access is necessary.

These controls do not encrypt the database or downloaded files. They do not make a compromised machine trustworthy. Test both accepted and rejected network paths before treating a changed deployment as secure.

04 Credential lifecycle

Environment credentials are read-only sources for the built-in provider profile. UI credentials are either process-session memory or AES-256-GCM vault entries. A random data-encryption key is wrapped using a separately salted, purpose-labelled password-derived key.

Explicit login can unlock an existing vault. A remembered browser session after restart can access local story data while the vault remains locked; re-entering the password restores plaintext provider access. Password change rewraps the data key rather than re-encrypting every secret entry.

Lock, final session expiry and disposal clear plaintext access. Terminal reset removes saved credentials with the owner and sessions while preserving stories and media. It uses the same DATA_DIR/DB_PATH resolution as startup and refuses missing or older-family databases.

Provider keys never belong in story prompts, saved JSON, public responses, screenshots, logs or issue attachments. Redaction reduces accidental exposure but is not permission to log complete upstream errors or request headers.

Custom provider endpoints are trusted destinations selected by the owner. HTTPS or supported loopback HTTP is required; OpenAI-compatible is a protocol claim, not proof of equal capabilities, retention or safety. Review each provider's terms and behaviour independently before sending sensitive material.

05 Untrusted output and semantic limits

A model response is a proposal, not a database command. Strict field, type, identity, evidence and ancestry checks constrain structured effects before any mutation. Character ownership, secret/public state, challenge decisions and quality permissions remain application rules.

Exact quotations support provenance but do not prove truth. A model can quote its own invented sentence, misunderstand a relationship, or reveal a secret in ordinary prose. Structural validation and a second model's approval cannot establish perfect semantic correctness.

The storyteller and optional reviewers receive bounded context that can include hidden facts and motives. Those facts are withheld from ordinary reader-state APIs, but a model may still narrate them prematurely. Do not store real-world secrets on the assumption that a fictional spoiler boundary is cryptographic.

Story text, imported text and previous dialogue are data. They do not authorise extra model calls, weaken output validation, change provider credentials or supply system-level instructions. Reviewers return bounded findings, not canon writes; repair uses the original authoritative context.

Render text safely and validate all exported data. A prompt-injection sentence must not become executable HTML or a command. No paid live benchmark is implied by deterministic test coverage; model behaviour needs separate, authorised, versioned evaluation.

06 Uploads, saves and historical data

Uploads are authenticated and CSRF-protected before parsing. Raster inputs have 20 MB and 40-megapixel ceilings, signature/container checks, fail-closed decoding, orientation normalization and metadata/animation removal. Active SVG and polyglot/trailing content are refused. Stored names are server-generated.

Playable saves are bounded gzip-JSON, not legacy manuscript ZIP archives. Import caps compressed and expanded bytes, validates exact fields, identities, cycles, ancestry, evidence and image digests before writes. It creates a new story with fresh IDs; staged files are cleaned on rollback.

Private saves are unencrypted and carry spoilers and directions. Provider consent, credentials and resumable request IDs never travel. Never open a save by executing its contents, trusting an embedded filesystem path or relaxing a failed preflight.

Startup inspects a private copy before allowing SQLite to touch an existing database. Old families and orphan journals are refused; sources and sidecars are not adopted or rewritten. Source-change checks require stopped writers for reliable operator handling and do not claim immunity to malicious filesystem races.

Back up complete stopped installations. A live copy can combine inconsistent database and journal states. Scratch inspection protects source files but is not a supported live-backup mechanism.

07 Reporting and operator checks

Report a suspected vulnerability privately through the repository's security advisory form. Include version, deployment shape, affected boundary, minimal reproduction and observed impact. Do not include real provider keys, passwords, cookies, full private saves or exploitable details in a public issue.

For suspected credential disclosure, revoke or rotate the affected upstream key through its provider, preserve a redacted incident record and inspect the actual exposure. Logging out cannot revoke a provider key or recall data already sent. Coordinate any destructive cleanup explicitly and retain recoverable evidence.

Before exposing an installation, verify loopback/proxy assumptions, HTTPS, allowed Host rejection, private API denial before unlock, CSRF denial, vault lock/re-entry and file permissions. Use dedicated fixture data rather than a real private story for screenshots or public reproductions.

Before sharing a file, identify it correctly: book for readers, playable save for trusted continuation, cold backup for installation recovery. A book excludes private fields by construction but can still contain a secret leaked into prose by the storyteller. Read it before sharing.

Security review is required for new provider calls, storage/import formats, network trust, authentication, public routes, logging and new data projections. The absence of a failing unit test is not proof that an expanded trust boundary has been reviewed.

08 Optional reviewer exposure and authority

Quality can send bounded story context, hidden truths and motives, direction, candidate prose and proposed effects to the standard model, memory-support model, or both. They can be different provider profiles. The review names every selected role/provider/model and its call ceiling before purchase. A provider credential remains transport-only; it is never story context or reviewer content.

Quality is off by default. A per-configuration device consent cannot be inferred from the earlier one-call approval. The server checks the reviewed plan identity, all role availability and current story revision at every paid boundary. Browser consent is a user-experience record, not an authentication or CSRF substitute. Import never brings consent or pending request authority from another device.

Reviewers are untrusted advisers: direct quotations support bounded issues but do not prove semantic accuracy. Story text and earlier dialogue are data, not permission to override the review contract. The original context remains binding during repair. Application validations still govern ownership, structured challenge outcomes and effect evidence. Unstructured prose can still be wrong or disclose a secret. Do not advertise perfect resistance or treat repeated model agreement as independent verification. Only call metadata and aggregate spend persist; rejected drafts and reviewer reasons do not become reader-visible history.

09 Relationships, episodes and return recaps

The public recap is behind the existing authentication and origin boundary. It returns only the selected ancestry's narrated summaries, active public commitments and public relationships, never character motives or private correction reasons. The episode question is reader-visible working direction, not a secret-lore field. Opening a recap or episode dialog makes no model request.

Relationships use qualitative aspects, not numerical affection scores. An evidenced development cannot rewrite protected world truth or supply an inhabited person's feelings. Structured validation narrows permitted effects; arbitrary model prose can still be inconsistent. Example journeys and mocked tests are not a live-model certification. Optional standard/memory-model checks follow the bounded quality contract; they remain fallible and require their own purchase authority.

10 Characters addressing the user

Fourth-wall dialogue is an optional Living-world presentation permission, not an authentication, knowledge or authority exception. The same narration purchase covers an optional bounded address. Never rejects structured addresses; Rarely adds a durable scene-gap check; Freely removes that gap but not cast/ownership validation. The narrator may not supply an inhabited character's address.

Instructions prohibit hidden-truth disclosure, invented user speech, pressure to return or spend, and using an aside to override resistance. Asides cannot be evidence for effects or adjudication. Structural enforcement is not a semantic guarantee for the model's unrestricted prose. Addresses form part of readable prose and therefore appear in exported books; they are not private annotations.

11 Influence and recall boundary

The new memory, evidence and challenge-review routes use the same authentication, same-origin and CSRF middleware as the game. Memory search filters secret and retired facts before limiting results; evidence reads reject other paths. Private correction reasons and challenge requirements remain absent. An invitation is constructed only from reader-visible facts and never makes a provider request.

Challenge review grants no authority to change state. The submitted reply still requires its exact reviewed revision, and changed grounds cannot turn a free repeat into a paid action behind the player's back. No new telemetry or provider logging is introduced. Model prose remains fallible despite validated rulings.

12 Resistance is not a security boundary

A character's refusal is a game-design contract, not an access-control mechanism for the real application. Story text, pleas and claimed authority cannot write the application-owned challenge decision directly. Evidence must exist as recorded world state, but models can still misinterpret how narrative evidence arose. Outcome-field and quotation checks are useful structural safeguards, not a proof of semantic consistency. Do not describe the system as immune to persuasion.

Private challenge motives, requirements and basis hashes are omitted from reader responses. Selected challenge definitions and relevant historical facts may enter the reviewed narrator context; they also belong in the private playable save, not reader-facing books. No new credentials, background calls or telemetry are added. World corrections remain explicit owner actions outside the fictional contest.

13 Images and saves

Image upload and binary save import remain behind authentication, same-origin and CSRF checks before body parsing. Uploaded rasters are container-checked, pixel/byte bounded, stripped of metadata/animation and normalized. Image reads are story-scoped, authenticated and no-store. SVG, forged containers and broken digests fail closed.

Painting sends only the selected passage and art direction to the reviewed Illustrator; it does not send private facts, motives or uploaded references. Each press permits one attempt. A rejection after provider completion still records its known charge; uncertain dispatch is not reported free.

Catalogue/reference painting instead sends the selected name, visible description, appearance/setting and art direction; story covers use title and premise. Private world lore and character motives/background are excluded from image prompts. No upload is silently used as a provider reference. Catalogue routes inherit the same auth/CSRF boundary, and asset reads bind both image and owning entry.

AI reference development has a different, explicit exposure: it sends every field currently entered in that studio, including private lore, motives and background, to the reviewed Storyteller. The response is untrusted structured data, validated into the selected world/character/Scribe shape and returned as an editable unsaved draft. One invalid response permits only one corrective call. Idempotency prevents duplicate purchases; the schema-23 journal preserves known charges or uncertain attempts across failure and restart. A draft never silently creates or updates a catalogue entry.

Narration may receive bounded frozen world lore, character profiles and Scribe craft alongside other private story context. References are untrusted setup data, not instructions or established events. Reader responses omit private catalogue fields; books omit reference portraits as well. Saves deliberately contain frozen private references and their story-owned images. A reusable catalogue deletion does not erase those copies from existing stories, saves or operator backups.

A playable save is unencrypted and contains spoilers, private motives and directions across all paths. It excludes credentials, provider configuration, consent and live request authority. Books exclude those private game surfaces altogether. Import has hard compressed/expanded bounds, validates all references and media, and creates a new copy transactionally without interpreting paths or storage keys from the file.

14 Reader boundary

The new reader starts private requests only after unlock. Lock clears prose, cast, facts, input drafts and credential fields. Route epochs discard late UI responses; leaving a story does not pretend to cancel a provider request already dispatched. All story text is rendered with text nodes, not interpreted HTML. Secret facts and private correction reasons are excluded from normal story responses, but selected hidden truth is disclosed as part of the paid narrator's provider exposure.

The client submits the provider/model shown in review. A changed storyteller role rejects the request before purchase; replaying a completed key remains free even after configuration changes. Paid consent follows the existing remembered-device policy: a review is not necessarily shown on every later click. Off permits one billable attempt; enabled quality has its own reviewed four- or six-call ceiling. Failures retain known charges and unknown attempts. Estimates are not caps.